



Security as GRC

Governing & Observing Agentic AI • Omer Farooq

FOUR-TIER GUARDRAIL ARCHITECTURE

1 Policy Inventory, ownership, risk tiering, approval gates.	2 Enforcement Tool permissions, parameter limits, action controls.	3 Oversight Human approval, alerts, SIEM detections.	4 Assurance Audit evidence, red-team tests, drift checks.
---	--	---	--

Classify every agent action as **Allow**, **Monitor**, **Require Approval** or **Block**.

GOVERNANCE RISKS TO LOWER

G1	Shadow agents, no inventory	G6	No audit evidence of decisions
G2	No named owner or approver	G7	Third-party model and tool supply chain
G3	Autonomy beyond delegated authority	G8	Unmanaged change and drift
G4	Regulatory non-compliance	G9	Cost and resource runaway
G5	Data protection and residency breach	G10	Reputational and legal exposure

2026 COMPLIANCE POSITION

STANDARD	STATUS	WHY IT MATTERS
EU AI Act	Applies 2 Aug 2026	Art. 50 transparency, Art. 49 registration
EU AI Act	Applies 2 Dec 2026	New Art. 5 prohibitions, AI-content marking
Digital Omnibus	In force 27 Jul 2026	High-risk duties move to Dec 2027 / Aug 2028
NIST AI RMF 1.0	2023, under revision	Govern, Map, Measure, Manage
ISO/IEC 42001	Published Dec 2023	First certifiable AI management system
OWASP GenAI Top 10	2026 edition, 4 Aug	Ranks Excessive Agency, Prompt Injection
MITRE ATLAS	2026.07	16 tactics, 101 techniques

OBSERVE AGENTIC AI

- Track data access, tool calls, approvals, traces, metrics and run recall.
- Keep append-only, redacted audit records and ship agent-specific detections to your SIEM.